

Generated artefact

SCOPE — ISMS Scope Statement

Version 8f96c01d1ee0 · generated · classification internal

Artefact	SCOPE
Generated from	the ISMS sources (front matter, registers, catalogue)
Source digest	sha256:8f96c01d1ee0829b...
Maintained by	Information Security Officer / ISMS Manager (Alex Rossi)
Approved by	Managing Director (Dana Weber)

Digital signature. When this PDF is produced by the release pipeline it carries a PAdES signature of the ISMS document-control key, shown at the bottom of this page; verify it with `isms verify` or any PDF reader. An unsigned copy is not a controlled document.

Digital signature (PAdES) — applied by the release pipeline. An unsigned copy is not a controlled document.

Digitally signed by
ISMS Document Control - UNTRUSTED DEVELOPMENT KEY
2026-08-20 22:09:20 CEST
UNTRUSTED DEVELOPMENT KEY - not a controlled copy

Item	Value
Certification target	ISO/IEC 27001:2022 — one group certificate covering all in-scope entities and sites
ISMS owner	Information Security Officer / ISMS Manager (Alex Rossi)
Management representative	Managing Director (Dana Weber)
Entities in scope	PaketPort Systems GmbH, PaketPort Deutschland GmbH, PaketPort Software s.r.o.
Sites in scope	7
Source	isms/context/organisation.yaml, interested-parties.yaml, legal-register.yaml

Purpose

This statement defines the boundaries and applicability of the information security management system (ISMS) of PaketPort Group as required by ISO/IEC 27001:2022 clause 4.3. It is generated from the organisation register so that the scope, the entity ids used in every document's `applies_to` field and the per-entity Statements of Applicability can never drift apart.

The organisation

PaketPort designs, installs and operates street-sited parcel lockers and the cloud platform behind them: a customer app, a parcel-routing and slot-allocation engine, carrier API integrations and a fleet-management plane that delivers signed firmware over the air to the Linux edge devices in the lockers. The group consists of the Austrian parent, which runs the platform and the Austrian locker estate, a German sales and field-service subsidiary that operates a growing German estate, and a Czech development centre. The ISMS was first certified for the Austrian entity and is being rolled out to the German and Czech entities under a single group certificate.

Sector. Parcel-locker logistics — postal and courier services (NIS2 essential entity in Austria)

External and internal issues (clause 4.1)

External issues

- NIS2 (Directive (EU) 2022/2555) classifies the Austrian parent as an essential entity; the German subsidiary is expected to qualify as an important entity under the national transposition.
- The Cyber Resilience Act brings product-security and vulnerability-handling obligations for the locker hardware and firmware as products with digital elements.
- Carrier partners require contractual security assurances, API availability commitments and incident notification, and increasingly ask for certification evidence before onboarding.
- Street-sited lockers are internet-exposed, physically accessible and continuously scanned.
- The platform depends on a single public cloud provider under a shared-responsibility model.
- Operations span three jurisdictions (AT, DE, CZ) with differing labour, privacy and NIS2 transposition rules.

Internal issues

- A small security function (one ISMS manager, one security engineer) serves the whole group.
- Rapid growth into Germany and Czechia means people, processes and tooling are still converging.
- Three generations of locker hardware with different firmware capabilities are in the field.
- Platform knowledge is concentrated in a few engineers (see risk R-013).
- Hybrid working is the norm for office roles; field technicians work entirely off-premises.

Interested parties and their requirements (clause 4.2)

Id	Interested party	Kind	Requirements	Addressed by
IP-01	Consumers using the lockers and the app	external	Confidentiality of names, contact details, addresses and parcel history; Availability of deposit and collection, including during backend disruption; Clear, timely communication if their data or parcels are affected by an incident	POL-CLS, POL-LEG, POL-BC, POL-IR, A.5.34
IP-02	Carrier partners	external	Contractual security clauses, annual attestation and a right to audit; Integrity and availability of the label, tracking and handover APIs; Incident notification within contractually agreed deadlines	POL-SUP, POL-NET, POL-IR, A.5.20, A.8.21

Id	Interested party	Kind	Requirements	Addressed by
IP-03	Retail and municipal site hosts	external	Safe, tamper-resistant locker installations on their premises; Agreed rules for site access, maintenance windows and incident contact	POL-PHY, A.7.1, A.7.4
IP-04	NIS2 competent authorities and CSIRTs (CERT.at and the DE/CZ counterparts)	external	Registration of the entities and up-to-date contact details; Risk-management measures per Art. 21 and management-body accountability per Art. 20; Incident reporting within 24 hours, 72 hours and one month per Art. 23	POL-ISMS, PROC-IR, POL-LEG, A.5.5
IP-05	Data protection authorities (Austrian DSB and the DE/CZ counterparts)	external	Lawful, secure processing of personal data with records of processing; Personal-data breach notification within 72 hours where required; An independent and adequately resourced Data Protection Officer	POL-LEG, PROC-IR, POL-CLS, A.5.34
IP-06	Shareholders and the management body	internal	Information security risk kept within the approved appetite; Protection of the management body from NIS2 liability through demonstrable governance; A maintained ISO/IEC 27001 certificate that carriers and tenders ask for	POL-ISMS, PROC-RISK, PROC-MR, A.5.4
IP-07	Employees, field technicians and contractors	internal	Clear, proportionate rules for using systems, data and devices; Training that fits their role, including locker-tampering guidance for field staff; A fair disciplinary process and a no-blame channel to report events	POL-HR, POL-AUP, POL-REM, A.6.3, A.6.8
IP-08	Cloud and technology suppliers	external	A clear shared-responsibility split and named security contacts; Security requirements communicated in agreements rather than assumed	POL-SUP, A.5.20, A.5.23
IP-09	Certification body and auditors	external	A controlled, versioned document set and a current Statement of Applicability; Traceable evidence that controls operate, and an internal audit programme	PROC-DOC, PROC-AUDIT, A.5.35, A.5.37
IP-10	Cyber insurer	external	Baseline controls as policy conditions, notably MFA on remote and privileged access and tested backups; Notification of incidents that may give rise to a claim	POL-ACC, STD-AUTH, POL-BC, PROC-IR, A.8.5, A.8.13

Organisational scope — legal entities

Id	Legal entity	Country	Role in the group	Headcount	NIS2 status	In scope
ENT-AT	PaketPort Systems GmbH	AT	Group parent. Operates the cloud platform, the Austrian locker estate, the security operations centre and all group-wide corporate IT and identity services; employs the platform, security and most development staff.	120	essential	Yes
ENT-DE	PaketPort Deutschland GmbH	DE	Wholly owned subsidiary. Sells, installs and services lockers in Germany and operates the German locker estate on the group platform; no software development and no hosting of its own.	35	important	Yes
ENT-CZ	PaketPort Software s.r.o.	CZ	Wholly owned development centre. Develops locker firmware and backend services together with the Vienna team and runs a hardware test lab; it operates no customer-facing service itself.	28	not-covered	Yes
ENT-IT	PaketPort Italia S.r.l.	IT	Minority-held reseller joint venture that markets lockers to Italian retailers. Operates its own IT and has no access to group systems beyond the partner portal.	6	not-covered	No

Physical scope — sites

Id	Site	Entity	Location	Kind	Functions	In scope
SITE-VIE-HQ	Vienna head office and security operations centre	ENT-AT	Vienna, AT	office	Group management; ISMS management; Security operations centre; Platform operations; Development; Corporate IT	Yes
SITE-VIE-DEPOT	Vienna logistics and locker-provisioning depot	ENT-AT	Vienna, AT	depot	Locker staging and provisioning; Spare-parts storage; Returns and secure disposal	Yes
SITE-AT-ESTATE	Austrian locker estate (street and retail sites)	ENT-AT	Austria-wide, AT	field-estate	Parcel deposit and collection; Edge devices with local transaction buffering	Yes
SITE-EU-CLOUD	EU public-cloud regions (primary and secondary)	ENT-AT	EU regions, AT	cloud-region	Cloud backend and data stores; Fleet management and OTA signing; CI/CD and source repositories; Central logging; Corporate identity and SaaS	Yes
SITE-MUC-OFFICE	Munich sales and field-service office	ENT-DE	Munich, DE	office	Sales; Field-service dispatch; Local spare-parts store	Yes
SITE-DE-ESTATE	German locker estate (pilot regions)	ENT-DE	Germany-wide, DE	field-estate	Parcel deposit and collection; Edge devices managed from the group platform	Yes
SITE-BRQ-DEV	Brno development centre and hardware test lab	ENT-CZ	Brno, CZ	office	Firmware and backend development; Hardware test lab; Pre-production locker units	Yes
SITE-MIL-OFFICE	Milan reseller office	ENT-IT	Milan, IT	office	Reseller sales	No

Services in scope

Id	Service	Description	Entities	In scope
SVC-01	Parcel deposit and collection via street-sited lockers	The core service for consumers and carriers: lockers accept and hand over parcels, buffer transactions locally and reconcile with the backend.	ENT-AT, ENT-DE	Yes
SVC-02	Customer mobile and web application	Consumer-facing app for notifications, collection codes, payments via the payment service provider and parcel history.	ENT-AT	Yes
SVC-03	Parcel-routing and slot-allocation engine	Backend engine that assigns parcels to lockers and compartments and coordinates carrier handover windows.	ENT-AT	Yes

Id	Service	Description	Entities	In scope
SVC-04	Carrier API integrations	Authenticated APIs for labels, tracking events and handover confirmations exchanged with carrier partners.	ENT-AT, ENT-DE	Yes
SVC-05	Locker fleet management and signed over-the-air firmware delivery	Device inventory, health monitoring, configuration and cryptographically signed OTA updates for the Linux edge devices.	ENT-AT, ENT-CZ	Yes
SVC-06	Locker installation and field service	Site survey, installation, maintenance and decommissioning of lockers by employed technicians and, in Germany, vetted subcontractors.	ENT-AT, ENT-DE	Yes
SVC-07	Firmware and backend software development	Development, testing and release of locker firmware and backend services across Vienna and Brno.	ENT-AT, ENT-CZ	Yes
SVC-08	Corporate IT and identity services	Group-wide identity provider, endpoint management, email and collaboration tooling provided by the parent to all in-scope entities.	ENT-AT, ENT-DE, ENT-CZ	Yes

Information systems

System	Description	Owner	Hosted at	Classification
Locker edge fleet (Linux devices)	Street-sited edge devices running the locker firmware with local transaction buffers.	Head of Platform & SRE	SITE-AT-ESTATE, SITE-DE-ESTATE	confidential
Cloud backend (customer app, routing engine, carrier APIs)	Production services and databases holding customer personal data and parcel events.	Head of Platform & SRE	SITE-EU-CLOUD	confidential
Fleet management and OTA signing service	Device management plane and the firmware-signing keys; the most sensitive system in scope.	Head of Platform & SRE	SITE-EU-CLOUD	restricted
Source repositories and CI/CD	Firmware and backend source code, build pipelines and release artefacts.	Software Engineering Lead	SITE-EU-CLOUD	confidential
Corporate identity and endpoint management	Group identity provider, MFA, device management and the office network.	IT Operations Lead	SITE-EU-CLOUD, SITE-VIE-HQ	confidential
Central logging and monitoring platform	Tamper-evident log store, alerting and dashboards for the fleet and the backend.	Head of Platform & SRE	SITE-EU-CLOUD	confidential
HR and payroll system (SaaS)	Employee master data and payroll for all entities, run as a software-as-a-service.	HR Manager	SITE-EU-CLOUD	restricted
Brno hardware test lab	Pre-production lockers and test harnesses; no production or customer data.	Software Engineering Lead	SITE-BRQ-DEV	internal

Interfaces and dependencies

External party	Direction	Description	Governed by
Carrier partners	bidirectional	Label, tracking and handover-event exchange over authenticated APIs; carriers also receive incident notifications under their contracts.	LEG-05, POL-SUP, POL-NET
Public cloud provider	bidirectional	Hosting of the backend, data stores and tooling. The provider's physical infrastructure is outside the scope and covered by its own certifications under the shared-responsibility model.	LEG-07, POL-SUP
Locker hardware manufacturer	inbound	Supplies enclosures, controllers and spare parts; firmware components are integrated and signed by PaketPort.	POL-SUP, POL-SDLC
Payment service provider	outbound	Hosted payment pages and tokenised payments for the customer app; card data never touches PaketPort systems.	POL-SUP
Retail and municipal site hosts	inbound	Provide locker sites, power and sometimes network uplinks; site staff have no access to the locker enclosure or systems.	POL-PHY
NIS2 competent authorities and CSIRTs	outbound	Registration, incident early warnings, notifications and final reports under Art. 23, and responses to supervisory requests.	PROC-IR, LEG-01
PaketPort Italia S.r.l. (reseller joint venture)	inbound	Out-of-scope reseller with partner-portal access only; treated as a supplier-type relationship.	POL-SUP
Field-service subcontractors (Germany)	inbound	Vetted subcontractors with time-limited access to maintenance tooling for the German estate.	POL-SUP, PROC-JML

Exclusions and their justification

Id	Excluded item	Justification
ENT-IT	PaketPort Italia S.r.l.	PaketPort holds 40 % and exercises no management control over the joint venture's processes or IT. The only interface is the partner portal, which is governed by the reseller agreement and treated as a third-party relationship under POL-SUP. Bringing the entity into scope would require contractual rights PaketPort does not have.
SITE-MIL-OFFICE	Milan reseller office	Office of the out-of-scope joint venture PaketPort Italia S.r.l.; no group systems or data are processed there beyond partner-portal access.

The physical infrastructure of the public cloud provider and the internal systems of carriers, suppliers and site hosts are outside the scope; the interfaces to them are listed above and governed by the documents named there.

Applicable legal, regulatory and contractual requirements

Id	Requirement	Kind	Applies to	Owner
LEG-01	NIS2 Directive — network and information security obligations	directive	all	Information Security Officer / ISMS Manager
LEG-02	General Data Protection Regulation	regulation	all	Data Protection Officer
LEG-03	Cyber Resilience Act — product security for lockers and firmware	regulation	ENT-AT, ENT-CZ	Software Engineering Lead
LEG-04	ISO/IEC 27001:2022 — certification requirements	standard	all	Information Security Officer / ISMS Manager
LEG-05	Carrier framework agreements — information security annex	contract	ENT-AT, ENT-DE	Head of Procurement
LEG-06	Labour and privacy law limits on screening and employee monitoring	law	all	HR Manager
LEG-07	Cloud service agreements and the shared-responsibility model	contract	all	Head of Platform & SRE
LEG-08	Cyber insurance policy conditions	contract	all	Managing Director

Documents with limited applicability

All approved documents apply to every entity in scope.

Approval

This scope statement is approved by the Managing Director together with POL-ISMS and maintained by the Information Security Officer / ISMS Manager. Changes to the organisation register are reviewed through pull requests; the approval history is the version-control history of `isms/context/organisation.yaml`.

Approval and control

Generated artefact. It is derived deterministically from the repository sources and regenerated by CI on every change; the approval record is the version-control history of the sources it is generated from.

Source digest sha256:8f96c01d1ee0829b7d819adde4910493a90efc651dff88f8739caa0026f3e31d · rendered by isms-as-code from the repository sources.